

Enumeration: It means discovering or listing information from a system. Suppose when testing a website, enumeration means discovering hidden things like: file, directories, users etc.

Page No.	
Date:	

GOBUSTER: THE BASICS

• Gobuster... what is it?

It is an offensive security tool which is used by penetration testers to discover hidden files, directories, and subdomains on a website.

• Here are some specific options we can configure to customize our commands:

1) `-t` or `--threads`: It is used to configure the no. of threads which means how much to scan at the same time. The default thread is 10.

2) `-w` or `--wordlist`: It configures a wordlist to use for iterating. Each wordlist entry is attached to the URL you included in the command.

3) `--delay`: It configures the amount of time to wait between sending two requests. It is a good practice to increase it because some website detectors enumerate by looking no. of request at a certain period of time.

4) `--debug`: It helps us to troubleshoot when our command gives unexpected errors.

5) `-o` or `--output`: It writes enumeration results to a file we choose.

- /admin etc

-x flag is used to configure gobuster to follow the redirect responses received from the sent requests if status code 301 was received.

• Case 1 (Normal dir scan)

It will try:

http://example.com/admin
 /login
 /images
 /backup

Case 2 (with extension)

Now It will try two things

/admin
 /admin.txt
 /login
 /login.txt

output:

/admin : status code: 200
 /login : 200
 /images: 201
 /backup 403

Here I don't know whether admin contains more or not.

If I want to know I must run scan for: http://example.com/admin.

So -x is added to add more guesses, it don't change the basic scanning behaviour.

• Subdomain enumeration: The dns mode allows gobuster to brute force subdomains.

• How to use dns mode?

gobuster dns -d example.com -w /path/to/wordlist

↓

this is the target domain. Its subdomain would look like. Example: admin.example.com

login.example.com
 images.example.com etc

you can configure this command by putting many flags which can be seen by: `gobuster dns --help`

- Vhost enumeration: Vhost mode will navigate to the URL created by combining the configured HOSTNAME (-u flag) with an entry in the wordlist.
OR

Gobuster Vhost mode is used to discover hidden virtual hosts (website) on the same server.

CONCEPT: I gave a target URL or website. Now gobuster will enumerate all the websites that are hosted on the webserver ~~on~~ on which my target website was hosted. But it only find Vhost (websites), it means the websites which are having the same ip as my target sharing the same ip.

The flags I can use with Vhost can be viewed by:
`gobuster vhost --help`

- Standard command for Vhost?
`gobuster vhost -u "http://example.com" -w path/to/wordlist`